

Case Study

Organization: Silver Oak University, Ahmedabad, Gujarat

Department: MSc. (Data Science)

Prepared By: Pandey Aman Satish

Date: 12-08-2026

Title: Case Study on British Airways 2018 Data Breach

1. Introduction:

British Airways (BA) is the historic, premium flag carrier airline of the United Kingdom. It operates as a full-service global network carrier, connecting passengers and cargo to major markets worldwide. BA stands as the second-largest UK-based airline based on fleet size and passenger volume, closely following the low-cost carrier easyJet.

The company is globally recognized for its signature British brand identity, premium customer service tiering, and strategic hub position at London Heathrow Airport, which serves as a vital artery for transatlantic corporate and leisure travel.

It serves over 200 destinations across more than 75 countries. BA's primary operational hub at London Heathrow (LHR), with secondary operations running out of London Gatwick (LGW) and London City Airport (LCY). It operates 258 active aircraft split between short-haul Airbus narrowbodies (A320/A321 families) and long-haul Boeing/Airbus widebodies (B777, B787 Dreamliner, A350, and the flagship A380 Superjumbo).

2. Profile:

- **Founded:** March 31, 1974 (via the merger of BOAC, BEA, Cambrian Airways, and Northeast Airlines).

- **Privatization:** 1987 (formerly state-owned, privatized under the Thatcher administration).
- **Headquarters:** Waterside, Harmondsworth, United Kingdom (near London Heathrow).
- **Parent Company:** International Airlines Group (IAG), formed in 2011 after a cross-border merger between British Airways and Spain's Iberia.
- **Global Alliance:** Founding member of the one world alliance.
- **Human Capital:** Employs approximately 40,000 corporate professionals, including 15,000 cabin crew, 3,600 pilots, and 5,500 aviation engineers.
- **Key Leadership:** Sean Doyle (Chairman and CEO).

3. Description of Data Breach:

The incident was a highly targeted, silent cyberattack carried out by a notorious cybercrime syndicate known as **Magecart**. Rather than breaking into a database and stealing static files, the hackers used a method called **digital credit card skimming**.

The attackers initially breached BA's internal network using **compromised login credentials** belonging to an employee of Swissport, a third-party cargo services provider. British Airways had failed to implement **Multi-Factor Authentication (MFA)** on this gateway, allowing the attackers to pivot from a supply-chain partner into the core environment.

Once inside, the hackers located the JavaScript code managing the airline's online booking systems. They injected a clean, **22-line malicious script** into a standard JavaScript library (Modernizr) used on BA's website and mobile application. Whenever a customer entered their billing and payment details to book a flight, the malicious script copied the data in real-time. The copied data was silently sent to a fraudulent, external server hosted on the domain baways.com. This domain was intentionally purchased by the hackers to mimic the legitimate airline and avoid raising security alarms.

4. Timeline of the Incident:

- **22/06/2018:** Attackers steal Swissport credentials and breach the BA network via a remote access gateway without MFA. They begin internal exploration.
- **21/08/2018:** Hackers modify the website and app JavaScript code, inserting the skimmer and activating data exfiltration.
- **21/08/2018 – 05/09/2018:** 15–16 days, payment details of every single customer checking out on the web or mobile app are captured and sent to baways.com
- **05/09/2018:** A third-party cybersecurity researcher discovers the malicious code and alerts BA. BA's internal security team verifies the threat and removes the script.
- **06/09/2018:** British Airways publicly announces the data breach and begins emailing affected users. They notify the UK Information Commissioner's Office (ICO).
- **08/07/2019:** The ICO issues a notice of intent to fine BA a staggering **£183.39 million** (1.5% of its 2017 global turnover) under strict new GDPR rules.
- **16/10/2020:** After appeals and negotiations, the ICO slashes the final fine to **£20 million** (\$26 million). The massive reduction explicitly accounts for the severe financial devastation caused to BA by the **COVID-19 pandemic**.

5. Causes of Data breach:

I. Supply Chain Vulnerability (Third-Party Access):

The initial entry point was a classic supply chain failure. Attackers stole remote network access credentials from an external employee working for **Swissport**, a third-party airport ground handling and cargo service provider.

II. Lack of Multi-Factor Authentication (MFA)

British Airways did not mandate Multi-Factor Authentication (MFA) on the remote access gateway used by contractors. Once the hackers had the stolen Swissport login credentials, they were able to log directly into BA's internal network with no secondary security.

III. Missing Privilege Management & Internal Segregation:

Once inside the network, the attackers easily pivoted from the non-sensitive third-party environment into BA's production network. The company lacked strict network segmentation, which allowed the threat actors to freely access and modify the application servers hosting the consumer-facing website and mobile app.

IV. Absence of File Integrity Monitoring (FIM):

The hackers directly injected a 22-line malicious JavaScript skimmer into BA's payment page code. BA had no automated **File Integrity Monitoring (FIM)** systems in place. As a result, the code on their live, public-facing website was altered for more than two weeks, and internal IT teams completely failed to notice the unauthorized changes.

V. Inadequate Security Testing:

Regulators noted that BA failed to conduct rigorous, continuous penetration testing or script-validation protocols. Simulating an attack on their payment pathways or auditing scripts running on user browsers would have easily flagged the rogue data transfer to the fraudulent domain (baways.com).

6. Impact of Data Breach:

- **The Regulatory Fine:** The UK Information Commissioner's Office (ICO) initially announced an unprecedented intent to fine BA **£183.39 million** (1.5% of its global turnover). While eventually mitigated to **£20 million** due to the economic devastation of the COVID-19 pandemic, it remained a massive direct cash penalty.
- **Remediation Expenses:** BA had to invest millions of pounds out-of-pocket to completely rebuild its digital infrastructure, hire forensic cyber investigators, and deploy endpoint detection software.
- **Loss of Premium Trust:** BA markets itself as a premium, full-service carrier. A breach of this scale severely eroded customer trust, especially among high-yield corporate and business-class travellers who value security.

- **Third-Party Auditing Overhaul:** The breach forced BA to dramatically restrict how vendors interact with its internal networks. They implemented rigid zero-trust access frameworks and mandatory multi-factor authentication for all supply-chain links.
- **The GDPR Effect:** The BA breach served as the world's first landmark case study for **GDPR enforcement**. It proved to the corporate world that data protection authorities were willing to issue massive, business-threatening fines for structural negligence. It fundamentally changed how global corporations approach data privacy compliance, elevating web application security and digital skimming (Magecart protection) to a high priority.

7. Risk Analysis Table:

Risk	Cause	Impact	Risk level
Supply Chain Compromise	Trusted third-party vendor credentials (Swissport) were stolen, providing a back-door entry point into the corporate network.	Attackers bypassed perimeter defenses completely by masquerading as legitimate users.	CRITICAL
Credential Hijacking	Lack of mandatory Multi-Factor Authentication (MFA) on remote contractor and employee login portals.	Compromised passwords immediately granted unrestricted entry into the internal environment.	CRITICAL
Malicious Code Injection	Lack of File Integrity Monitoring (FIM) to detect unauthorized changes to live	A rogue 22-line JavaScript script sat undetected on the checkout page for 15 days, stealing payment data in real-time.	HIGH

	website source code.		
Regulatory & GDPR Non-Compliance	Failure to protect customer PII and failure to discover the system breach internally.	Triggered an intensive UK ICO investigation, resulting in a £20 million fine and massive class-action lawsuits.	HIGH
Delayed Detection	Absence of real-time behavioral analytics or anomaly alerts tracking outbound network data transfers.	Internal security teams remained blind to the breach; it was only stopped after a third-party researcher alerted BA.	MEDIUM
Financial Data Retention Failure	Storing restricted CVV/CVC credit card security codes within accessible system memory layers.	Severe compliance breach; roughly 77,000 customers had their highly sensitive card verification codes compromised.	MEDIUM

8. Mitigation measures:

- ✓ Mandatory Multi-Factor Authentication (MFA)
- ✓ Principle of Least Privilege (PoLP)
- ✓ Zero-Trust Network Access (ZTNA)
- ✓ File Integrity Monitoring (FIM)
- ✓ Robust Content Security Policy (CSP)
- ✓ Sub resource Integrity (SRI)
- ✓ Strict PCI-DSS Compliance
- ✓ Tokenization of Payment Data
- ✓ Security Information and Event Management (SIEM)

✓ Regular Penetration Testing & Vulnerability Scanning

9. Conclusion:

The 2018 British Airways data breach stands as a definitive blueprint for modern corporate vulnerability, illustrating that a global company's digital perimeter is only as resilient as its weakest third-party vendor link. It proved that traditional, siloed security models are obsolete. To survive sophisticated cyber threats, corporations must transition to strict Zero-Trust architectures where internal networks are segmented and no user—internal or external—is granted unverified access.

Furthermore, this incident marked a historic turning point for global corporate governance by serving as the first major real-world application of GDPR enforcement. The regulatory response signaled to boards of directors worldwide that digital negligence is no longer just an "IT department issue." Instead, data protection and cybersecurity have been permanently elevated to core financial liabilities, directly tied to corporate compliance, brand equity, and shareholder value.

10. Outcomes:

- British Airways was hit with a £20 million (\$26 million) fine by the UK Information Commissioner's Office (ICO). BA was mandated to carry out a comprehensive, multi-million-pound overhaul of its digital infrastructure. This included implementing automated code checking, deploying behaviour analytics software, and rebuilding its web checkout architecture.
- The breach proved that cybersecurity is a core business continuity threat, not just a technical issue. It forced corporate boards to treat cyber risks with the same urgency as financial or legal risks.
- The breach became a classic textbook study on digital supply chain vulnerabilities, prompting industries worldwide to mandate Multi-Factor Authentication (MFA) and continuous code integrity monitoring across all public platforms.